DEV-03 · Disk Encryption & BitLocker Recovery Key Handling

How organization devices are encrypted, how recovery keys are held, and how to find and fix a device whose key is not where it should be.

Field	Value
Document ID	DEV-03
Version	1.0 · Known Good edition, by Kevin Zelman
Catalogue domain	C. Device Usage
Operating tier	Tier 2 — Advanced Technical Services. Key retrieval for a user is Tier 1 or Tier 2; policy and remediation design is Tier 3.
Review cycle	Every six months while the estate is mixed, then annually.
Related existing policy	Your sensitive data disposal policy, if you have one.

1. Purpose

Encryption without a recoverable key is not a security control. It is a mechanism for permanently destroying organization data at an unpredictable moment. Most organizations that have ever changed encryption tools have devices in exactly that state and do not know how many.

> **How it usually happens**
>
> A move from one encryption tool to another plans to decrypt every device and re-encrypt it under Intune with the key escrowed in Entra. The plan only reaches machines that are online and healthy at the time.
>
> That is why some devices show a key in Entra and others show nothing.
>
> A device in the second category is encrypted, in use, and unrecoverable the first time it prompts for a recovery key. Nothing about its appearance to the user distinguishes it from a healthy one.

2. The three states the estate is in

State	What it means	What to do
Encrypted, key escrowed in Entra	Correct. Recoverable, and safe to wipe or reissue.	Nothing. Record the key ID against the device.

State	What it means	What to do
Encrypted, no key escrowed	The dangerous state. Data is unrecoverable at the next recovery prompt, and the device cannot be safely reissued or closed out on a leaver checklist.	Remediate per §6. Priority work, not backlog. Do not wipe.
Not encrypted	Non-compliant, but not at risk of unrecoverable loss.	Apply the policy, then verify escrow per §5. The safer of the two failures.

The first task under this document is to find out how many devices are in each state. That number is usually not known, and every other decision depends on it.

3. The standard

- Every organization-owned Windows device is encrypted with BitLocker, managed by Intune, with the recovery key escrowed in Entra ID.
- Every organization-owned macOS device is encrypted with FileVault, with the recovery key escrowed. A macOS device with FileVault on and no escrowed key carries exactly the same risk as its Windows equivalent, and this is easy to overlook where macOS management is still maturing (DEV-09).
- There is no device class at the organization for which an unescrowed key is acceptable — including labs, loaners, kiosks and conference-room machines.
- Escrow is verified by looking, per device, and recorded. It is never inferred from the encryption policy having been applied.
- The key ID is recorded in the inventory against the device. The key itself stays in Entra and is never copied into a ticket, a spreadsheet or a document.

4. How escrow actually works, and how it silently fails

Silent BitLocker enablement backs the recovery key up to Entra automatically when encryption begins — but only under conditions that are easy to miss and produce no error when unmet.

Escrow requires	When it is absent
The device is Entra joined	Automatic backup does not occur. This is the most common single cause.
No policy conflict blocking the backup	Encryption can proceed while the backup is blocked — the worst combination.
The backup succeeding before encryption starts	Encryption completes and the key exists only on the device.
The device being online and healthy at the moment of the change	Exactly the condition a tool migration cannot guarantee, which is why estates end up mixed.

One further limit worth knowing before it is diagnosed the hard way: Entra holds a maximum of 200 recovery keys per device. A device that has churned through rotations near that ceiling will fail silent encryption because the key backup fails first.

5. Verification

5.1 One device

1. Open the device in Intune, and under Monitor select Recovery keys.
2. Where Intune states that no BitLocker key was found for the device, that is a finding and not a display problem. Treat it as §6.
3. Record the key ID — not the key — against the device in inventory.

5.2 A population

1. Use the Intune encryption report (Devices → Monitor → Encryption report) to list encryption state across the estate.
2. For every device the report shows as encrypted, confirm a key exists. The report tells you the device is encrypted; it is not by itself proof of escrow.
3. Produce the §2 three-state count. Publish it internally — this is the number the remediation is measured against.
4. List every device that has not checked in. Silent devices are where the current gap came from, and they will not appear in any report as a problem.

6. Remediation

1. Confirm the device is Entra joined. If it is not, resolve that first — most cases end here.
2. Check for policy conflicts between the encryption profile and any security baseline.
3. Trigger a key rotation from Intune, then re-verify per §5.1. Rotation generates a new recovery password and stores it in Entra, which resolves the majority of cases without touching the volume.
4. If rotation produces no key, escalate to Tier 3. Do not wipe, reimage or reissue — the volume is currently unrecoverable and a wipe makes that permanent and irreversible.
5. Where the device must be recovered and no key can be produced, confirm resident data is safe, then reimage via Autopilot. It returns enrolled, encrypted and escrowed.
6. Record the remediation and the resulting key ID.

7. Retrieving a key for a user

> **Retrieval is an account action**
>
> Verify identity per ACC-06 before reading out a recovery key. A 48-digit key handed to the wrong person defeats the encryption entirely, and “I am locked out of my laptop” is a completely plausible story for somebody holding a stolen device.
>
> Privileged-account rules do not apply here, but V1 or V2 verification is strongly preferred for a key retrieval regardless of whose device it is.

1. Verify identity per ACC-06 and record the tier used.
2. Confirm the device is assigned to that person in inventory (DEV-01 §10). A device with no recorded primary user is a different conversation.

3. Retrieve and read out the key. Do not paste it into the ticket, an email or a chat message.
4. Record that a retrieval occurred, the key ID, and the verification tier. Every retrieval is separately audited in Entra under Key Management.
5. Afterwards, rotate the key. A key that has been read aloud should not remain the standing recovery key. Retrieval requires an Entra role carrying the recovery-key read permission — Cloud Device Administrator, Helpdesk Administrator, Intune Administrator, or a purpose-built custom role. Grant the narrowest role that works and review holders quarterly under ACC-07.

8. Before any wipe, reimage or reissue

> **The check that must never be skipped**
> Confirm the recovery key is escrowed BEFORE wiping. A wipe of an unescrowed encrypted volume is unrecoverable.
> This is also the check ACC-01 §7.2 step 8 depends on to close a leaver ticket, and DEV-01 exit criterion 6 to call a device enrolled. Three separate procedures rely on this one action, which is why it has its own document.

9. Service levels

Activity	Commitment (per GOV-06)
Key retrieval for a verified user	P2 — 30 minutes. Somebody is locked out of their computer.
Encrypted device found with no escrowed key	P2 — remediation started the same coverage day.
Estate-wide three-state count (§5.2)	Once, as Tier 3 protected capacity, then monthly.
Policy conflict blocking escrow across several devices	P1 at Tier 3 — it is silently creating unrecoverable devices.

10. Measurement

- Count of devices in each of the three §2 states, monthly. The headline number is “encrypted with no escrowed key” and the target is zero.
- Devices not checked in for 30 days. These are unmeasurable and therefore unmanaged.
- Key retrievals per month, with verification tier recorded.
- Remediation attempts that failed after rotation — these indicate a systemic cause rather than individual device faults.

11. Records

Record	Held in	Retention
Key ID against each device	Inventory	Life of the asset
Verification of escrow at enrollment	Ticket (DEV-01 criterion 6)	Life of the asset + 1 year

Record	Held in	Retention
Remediation actions and outcomes	Ticket + project record	3 years
Key retrievals: who, when, verification tier, key ID	Ticket + Entra Key Management audit	3 years
Monthly three-state count	GOV-06 monthly pack	3 years

12. Related documents

ID	Title	Relationship
DEV-01	Device Enrollment & Lifecycle	§9 of that document is the operational summary; this is the full standard. Exit criterion 6 depends on §5 here.
DEV-02	Device Compliance & Configuration Baseline	Where the encryption policy is defined.
DEV-09	macOS Device Management Standard	FileVault escrow for Macs.
DEV-15	Device Reassignment, Wipe, Retirement & Disposal	§8 is its precondition.
DEV-16	Lost, Stolen or Compromised Device Response	Depends on knowing whether the volume is recoverable.
ACC-01	Account Lifecycle	§7.2 step 8 leaver check.
ACC-06	Identity Verification	Mandatory before §7.
ACC-07	Privileged & Administrative Account Standard	Quarterly review of who can read keys.
Disposal Policy	the organization Disposal of Sensitive Data Policy (existing)	Governs the disposal end of §8.

Appendix A — Verification and remediation card

	Check	If it fails
1	Intune → device → Monitor → Recovery keys. Key present?	“No BitLocker key found” is a finding. Go to 2.
2	Is the device Entra joined?	No → automatic backup never happens. Fix the join. Most cases end here.
3	Policy conflict between encryption profile and a security baseline?	Conflict can block backup silently while encryption proceeds. Resolve, then 4.
4	Trigger key rotation from Intune. Re-check 1.	Key now present → record the key ID and close.
5	Still no key?	ESCALATE to Tier 3. Do NOT wipe, reimage or reissue.
6	Device must be recovered and no key can be produced.	Confirm resident data is safe, then reimage via Autopilot — it returns escrowed.

Retrieving a key for a user: verify per ACC-06 first, never paste the key into a ticket, and rotate it afterwards.

Part of the Known Good SOP Catalog by Kevin Zelman, written for small IT shops, contractors and consultants, career-changers and help desk technicians. Adapt the names, tiers and times to your own shop: the times here are cushion, not a promise.